WawID

Plan de déploiement

Infrastructure haute disponibilité hébergée dans les datacenters au Sénégal, sauvegardes et reprise d'activité

Version 1.0 · 19/10/2026
WAW Telecom · Document de travail — données de démonstration

Sommaire

Lire ce plan
Synthèse
1. Objectifs et exigences
2. Topologie cible
3. Stratégie de sauvegarde
4. Haute disponibilité et reprise après sinistre
5. Sécurité et conformité
6. Phases de déploiement
7. Environnements
8. Exploitation
9. Nomenclature par site
10. Risques et mesures
11. Existant, cible et à développer

Ce plan décrit comment WawID passe du démonstrateur actuel à une exploitation nationale **souveraine et haute disponibilité** : deux centres de données actifs au Sénégal, un troisième site de sauvegarde (coffre), des serveurs locaux dans chaque poste frontière, une stratégie de sauvegarde, les procédures de bascule et de reprise, les phases de déploiement, l'exploitation et les risques. Il s'adresse à WAW Telecom, à la DPAF, à Sénégal Numérique, aux hébergeurs, à la DGCPT et aux intégrateurs.

Il complète `docs/ARCHITECTURE.md` (architecture nationale cible) et les pages *Guide d'installation — Sénégal* (installation des postes, recette, mise en service), *Déploiement et configuration* (démonstrateur, variables, pont NFC) et *Sécurité, données personnelles et conformité*. Le *Guide utilisateur par profil* décrit ce que les utilisateurs vivent en mode dégradé et lors d'une bascule.

Lire ce plan

Mention	Signification
Existant	Fonctionne aujourd'hui dans le démonstrateur (code du dépôt).
Cible	Architecture retenue pour la production nationale ; elle reste à construire.
À développer	Nécessite du développement logiciel absent du code actuel.
Recommandation	Choix conseillé ; il n'engage aucune partie tant qu'il n'a pas été décidé.
À vérifier	Fait, certification, capacité ou point juridique à confirmer auprès de l'interlocuteur compétent avant toute décision.

Ce plan ne contient ni prix, ni niveau de service contractuel, ni date : les montants, engagements et calendriers résulteront des consultations et des conventions. Les durées citées sont **indicatives**.

Synthèse

Décision	Recommandation
Hébergement	Uniquement au Sénégal, sans cloud étranger pour les données personnelles
Site A (principal)	Datacenter national de Diamniadio (État, exploité par Sénégal Numérique SA)
Site B (secondaire actif)	Centre de données commercial certifié Tier III, sur un site et un réseau électrique distincts ; option privilégiée : Sonatel (Orange) à Rufisque, alternative : Yas (ex-Tigo) à Diamniadio
Site C (coffre)	Site sécurisé distinct, hors de la zone Dakar–Diamniadio si possible, recevant des copies chiffrées immuables et des copies hors ligne
Mode de fonctionnement	Actif-actif pour les niveaux sans état (web, API) ; base de données en primaire/secours avec réplication synchrone A → B ; réplication asynchrone vers C
Postes frontière	Grappe locale de deux serveurs par poste, avec copie des listes et moteur de décision local ; le contrôle continue même si les deux sites centraux sont injoignables
Objectifs	Disponibilité du central 99,95 % ou plus ; RPO 0 dans un site ; RPO ≤ 5 min et RTO ≤ 1 h en cas de perte d'un site
Sauvegarde	Règle 3-2-1-1-0, restauration testée chaque trimestre

Décision	Recommandation
Démonstrateur Netlify	Conservé pour les démonstrations et la formation, sans aucune donnée personnelle réelle

1. Objectifs et exigences

Souveraineté

- **Données et clés au Sénégal** : les données nominatives, biométriques, de voyage et financières, ainsi que les clés cryptographiques qui les protègent, sont hébergées et gérées sur le territoire national, conformément à la loi n° 2008-12 du 25 janvier 2008 sur la protection des données à caractère personnel et sous le contrôle de la CDP. Le régime exact (déclaration ou autorisation) est **À vérifier** auprès de la CDP.
- **Pas de cloud étranger** pour les données personnelles. Une copie chiffrée à l'étranger exigerait une autorisation explicite de la CDP et de l'État ; elle **n'est pas recommandée**.
- **Maîtrise des clés** : les clés de signature et de chiffrement sont générées et conservées dans des HSM situés dans les sites A et B, sous le contrôle de l'État (cérémonies de clés documentées).
- **Réversibilité** : l'État conserve la propriété des données et des codes ; les formats d'export (SQL, objets, journal d'audit) sont documentés.

Objectifs de disponibilité et de reprise

Les valeurs ci-dessous reprennent et précisent celles de `docs/ARCHITECTURE.md`. Ce sont des **objectifs de conception**, pas des engagements contractuels.

Indicateur	Objectif	Remarque
Disponibilité des services centraux	99,95 % ou plus par an	Environ 4 h 20 min d'indisponibilité non planifiée par an au maximum
Perte de données dans un site (panne d'un serveur, d'une baie)	RPO 0	Réplication synchrone entre nœuds
Perte d'un site central	RPO ≤ 5 min (0 visé tant que la réplication synchrone A → B est saine) ; RTO ≤ 1 h	Bascule vers l'autre site central
Perte simultanée des deux sites centraux	RPO selon la dernière copie reçue par le site C ; RTO à définir (reconstruction)	Les postes poursuivent le contrôle en mode hors ligne pendant la reconstruction
Capacité de contrôle au poste	100 %, y compris sans liaison avec le central	Serveur de poste (À développer)
Synchronisation des listes vers les postes	Moins d'une minute	Objectif de `docs/ARCHITECTURE.md`
Tests de bascule	Deux fois par an au minimum	Voir la section 4

Continuité du contrôle aux postes

Le contrôle frontière ne doit jamais dépendre de la disponibilité du central. Chaque poste dispose d'un **serveur de poste** (grappe de deux nœuds) qui exécute le même moteur de décision que le central (`public/shared/engine.js`), conserve une copie chiffrée des listes de surveillance et met les passages en file d'attente jusqu'au retour de la liaison (« stockage et retransmission »). Ce mode est **À développer** : le démonstrateur n'a pas de mode hors ligne.

Capacité

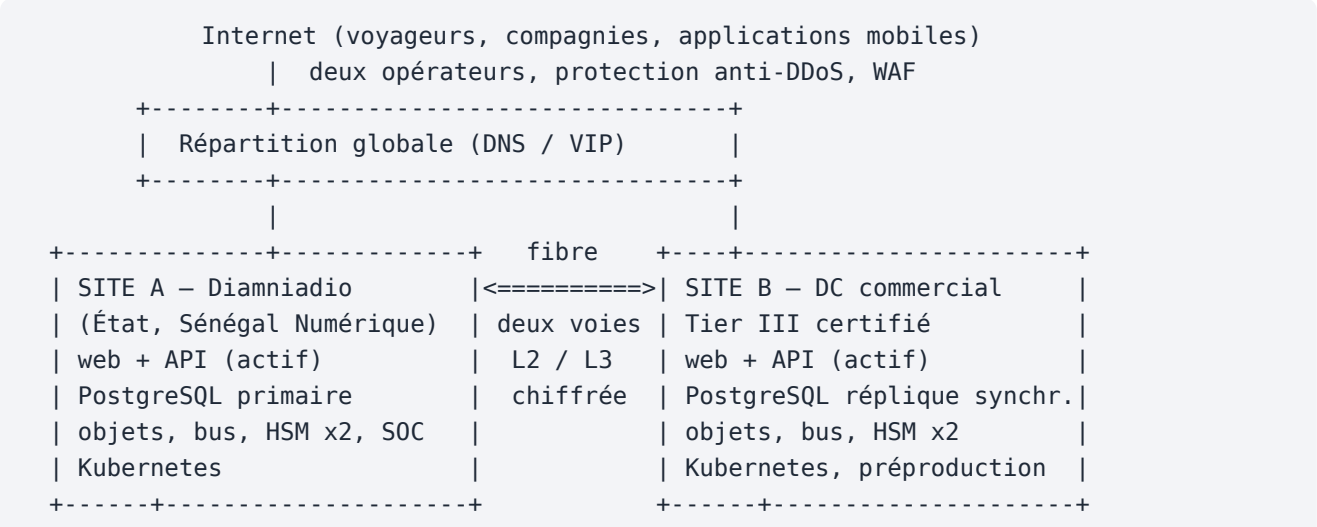
Le dimensionnement repose sur les hypothèses de `docs/ARCHITECTURE.md`, à confirmer avec la DPAF et avec les statistiques de trafic de l'AIBD et de l'ANACIM.

Indicateur	Estimation	Dimensionnement cible (×5)
Passages annuels tous postes	~6 millions	30 millions
Pointe AIBD	~3 000 voyageurs/heure	15 000/h
Transactions de contrôle (pointe nationale)	~2/s	10/s soutenu, 50/s en rafale
Interrogations des listes	~10/s	50/s
Demandes e-Visa	~300 000/an	1,5 million/an
Base biométrique	~10 millions de personnes à 5 ans	50 millions
Postes, guichets, eGates	6 postes, ~60 guichets, ~20 eGates	60 postes, 600 guichets, 200 eGates
Rétention	5 ans (paramétrable)	~150 millions de passages

Chaque site central doit pouvoir porter **seul** 100 % de la charge de pointe : en actif-actif, chaque site fonctionne donc à 50 % au plus de sa capacité en situation normale.

2. Topologie cible

Vue d'ensemble





Choix des sites

Les informations ci-dessous proviennent de sources publiques (presse spécialisée, annuaires de centres de données). Elles doivent toutes être confirmées par les opérateurs lors de la consultation.

Centre de données	Opérateur	Faits publics	Statut
Datacenter national de Diamniadio	État, exploité par Sénégal Numérique SA (ex-ADIE)	Inauguré en juin 2021 ; environ 1 000 m² de salles techniques ; 1,4 MW ; présenté comme « de type Tier III »	Aucune certification Uptime Institute confirmée publiquement : **À vérifier**
Yas (ex-Tigo, Sen Connect) Diamniadio	Opérateur commercial	Certifié Tier III par l'Uptime Institute (2017), colocation commerciale	Nature (conception ou construction) et validité de la certification **À vérifier**
Sonatel (Orange) Rufisque	Opérateur commercial	Annoncé Tier III (« Tier 3+ ») ; deuxième salle ajoutée ; extension (phase 3) signalée en 2025 par une seule source de presse ; proximité annoncée de l'atterrissement du câble 2Africa	Certification, capacité et extension **À vérifier**
Free Sénégal Diamniadio	Opérateur commercial	Conçu selon le niveau Tier III	Non certifié selon les informations disponibles
PAIX Dakar, Onix	Opérateurs de colocation	Cités dans des annuaires de centres de données	Caractéristiques **À vérifier**

Site A — principal (Recommandation)

Le **Datacenter national de Diamniadio** est recommandé comme site principal : hébergement souverain de l'État, opéré par Sénégal Numérique, cohérent avec la doctrine des fichiers régaliens. Points à confirmer dans la convention avec Sénégal Numérique : capacité disponible (surface, puissance, refroidissement), niveau de redondance réel, sécurité physique, accès des équipes de WAW Telecom, raccordements opérateurs disponibles, conditions de colocation de HSM, niveaux de service. Aucun engagement n'existe à ce jour.

Site B — secondaire actif (Recommandation)

Le site B doit être un centre de données **certifié Tier III**, sur un **site physique distinct** et alimenté par un **poste électrique distinct**, raccordé par des chemins de fibre différents de ceux du site A, tout en restant assez proche pour la réplication synchrone (latence de l'ordre de la milliseconde).

Critère	Sonatel (Orange) Rufisque	Yas (ex-Tigo) Diamniadio
Séparation géographique avec le site A	Meilleure : autre commune, distance de l'ordre d'une quinzaine de kilomètres à vol d'oiseau (longueur réelle de fibre à mesurer)	Faible : même pôle urbain que le site A, risques régionaux partagés (inondation, poste électrique, accès routier)
Réplication synchrone	Possible (distance inférieure à 20 km environ)	Possible (très courte distance)
Certification	Annoncée Tier III, **À vérifier**	Tier III Uptime Institute (2017), validité **À vérifier**
Alimentation et réseau distincts du site A	Probable, **À vérifier**	**À vérifier** : risque de poste électrique commun
Neutralité vis-à-vis des opérateurs	Centre d'un opérateur télécom : l'accès des autres opérateurs (deuxième lien) doit être garanti par contrat	Idem
Connectivité internationale	Proximité annoncée du câble 2Africa (À vérifier)	À vérifier

Recommandation : **Sonatel Rufisque** en premier choix pour la séparation géographique, **Yas Diamniadio** en alternative si la certification et la capacité de Rufisque ne sont pas confirmées. Dans les deux cas, la convention doit garantir l'arrivée d'au moins un opérateur différent de l'exploitant du centre.

Site C — coffre de sauvegarde (Recommandation)

Le site C n'héberge pas de production. Il reçoit :

- des copies **chiffrées et immuables** (stockage objet avec verrouillage en écriture unique, ou appliance de sauvegarde immuable) alimentées en continu depuis A et B ;
- des copies **hors ligne** (bandes ou disques chiffrés déconnectés) renouvelées chaque semaine et conservées dans un coffre ;
- les sauvegardes des clés HSM (sous forme chiffrée, partagées entre plusieurs dépositaires) ;
- un **arbitre** léger (témoin de quorum) pour éviter qu'A et B se croient tous deux principaux en cas de coupure entre eux, si la liaison du site C le permet.

Le site C doit se trouver hors de la zone Dakar–Diamniadio–Rufisque si possible (autre région), dans une installation de l'État ou une installation sécurisée distincte, à identifier avec Sénégal Numérique (**À vérifier**). Aucune copie n'est envoyée à l'étranger.

Modes de fonctionnement par couche

Couche	Mode	Détail (Cible)
Web (fichiers statiques des plateformes)	Actif-actif A et B	Servi par un niveau web derrière le WAF, dans chaque site
API WawID	Actif-actif A et B	Conteneurs sans état, au moins trois instances par site ; même code dans les deux sites
Base de données (PostgreSQL)	Primaire / secours synchrone	Gestion de grappe par Patroni ou équivalent ; primaire en A, réplique locale en A, au moins une réplique **synchrone** en B (une transaction n'est validée qu'après écriture en B) ; réplication asynchrone et archivage continu des journaux (WAL) vers C
Stockage objet (biométrie, documents, exports)	Répliqué entre A et B	Compatible S3 (par exemple MinIO ou Ceph), effacement codé dans chaque site, réplication entre sites ; verrouillage d'objet pour les archives
Bus d'événements (Kafka ou équivalent)	Répliqué	Grappe étendue sur A, B et un arbitre, ou une grappe par site avec réplication ; choix à valider
Biométrie (ABIS)	Actif / secours	Selon les capacités du fournisseur retenu ; galeries répliquées dans les deux sites
HSM	Paire par site	Clés de signature des QR, des sessions et d'ancrage du journal d'audit ; clés de chiffrement des sauvegardes ; clés répliquées par cérémonie
Orchestration	Une grappe Kubernetes (ou équivalent) par site	Déploiements identiques pilotés depuis un dépôt de configuration unique
Identité (OIDC, MFA)	Actif-actif	Annuaire et fournisseur d'identité répliqués (À développer)
Répartition globale	DNS avec bascule et contrôle de santé, ou adresse virtuelle annoncée par les deux sites (anycast ou double raccordement)	TTL courts ; bascule automatique sur perte de santé d'un site
Protection	WAF, anti-DDoS, PKI	WAF dans chaque site ; protection volumétrique fournie par les opérateurs (À vérifier) ; PKI de l'État ou dédiée pour les certificats serveurs, agents et équipements

Réseau

Liaison	Recommandation
Internet des sites A et B	Deux opérateurs différents par site (par exemple deux parmi Sonatel/Orange, Free, Expresso, Yas), chemins physiques distincts ; exigence de diversité, sans préjuger du choix des opérateurs

Liaison	Recommandation
Liaison A ↔ B	Fibre noire ou liaison de niveau 2 ou 3 dédiée, sur **deux chemins physiques distincts**, chiffrée ; latence mesurée avant la mise en service de la réplication synchrone
Liaison vers C	Liaison chiffrée dédiée, à débit suffisant pour l'archivage continu ; les copies hors ligne sont transportées physiquement selon une procédure sécurisée
Postes frontière	MPLS ou VPN chiffré vers A et B (opérateur 1), secours 4G ou VSAT (opérateur 2) ; bascule automatique
Compagnies aériennes	Internet, via le WAF, sur la passerelle `POST /api/carrier/messages` avec la clé `X-Carrier-Key` (Existant) ; certificats clients (mTLS) envisagés (Recommandation)
Interpol	Raccordement I-24/7 via le BCN Interpol de Dakar, selon les modalités définies avec Interpol (**À vérifier**)
WAPIS, FPR, DAF (état civil, passeports)	Liaisons privées ou VPN avec les services détenteurs, après accords (**À vérifier**)
DGCPT / Trésor	Accès des agents du Trésor par VPN ou réseau privé de l'administration ; échanges de fichiers de rapprochement chiffrés
Administration de la plateforme	Uniquement par bastion, depuis le réseau d'administration (voir la section 5)

Exposition et domaines

Aujourd'hui, les quatre plateformes sont servies sous un même domaine, avec des chemins distincts (Existant) : espace DPAF `/dpaf/`, plateforme voyageurs `/`, applications mobiles `/app/`, plateforme des compagnies `/compagnies/`, kiosque `/gate/`. En production, chaque plateforme reçoit son domaine (Recommandation) :

Plateforme	Domaine indicatif	Exposition
Voyageurs (portail, aide, e-Visa, pré-enrôlement eGate)	`www.<domaine>` ou `voyageurs.<domaine>`	Internet, derrière le WAF
Applications mobiles et leur API	`app.<domaine>` (page) et `api.<domaine>` (routes publiques)	Internet, derrière le WAF
Compagnies aériennes (plateforme et passerelle)	`compagnies.<domaine>`	Internet, derrière le WAF, limitation de débit
Espace DPAF	`dpaf.<domaine>`	Réseau privé ou VPN uniquement, jamais sur Internet
Kiosques eGate	Servis par le serveur de poste sur le réseau du poste	Réseau du poste uniquement

Le code appelle l'API par des chemins relatifs (`/api/...`) : chaque domaine route donc `/api/*` vers le niveau API. Les liens entre plateformes et les ressources partagées (`/shared/`) sont à vérifier lors de la migration. Le cookie de session étant lié au domaine, séparer les domaines sépare aussi les sessions entre plateformes.

Postes frontière (edge)

Élément	Cible (À développer)
Serveurs	Grappe de deux nœuds par poste (AIBD, PDK, ZIG, ROS, KID, KAR) ; capacité de l'AIBD à dimensionner pour la pointe
Données locales	Copie chiffrée des listes de surveillance, des e-Visa approuvés et des listes de certificats CSCA, synchronisée en moins d'une minute
Décision	Moteur `public/shared/engine.js` exécuté localement ; comparaison biométrique 1:1 locale
Passages	Enregistrés localement puis retransmis au central (stockage et retransmission), avec identifiant unique pour éviter les doublons
Équipements rattachés	Guichets, eGates, kiosques, CCTV, lecteurs de plaques ; ils dialoguent avec le serveur de poste, qui dialogue avec le central
Énergie	Onduleur et groupe électrogène ; autonomie dimensionnée selon les coupures observées
Réseau	Deux liaisons (principale et secours), pare-feu local, segmentation

Ce qui ne fonctionne pas sans liaison : interrogation en temps réel des sources externes (Interpol, WAPIS), recherche biométrique 1:N, réception des nouveaux messages API/PNR, connaissance des e-Visa approuvés ou révoqués après la coupure. Ces limites sont compensées par la copie locale et le rapprochement au retour de la liaison.

3. Stratégie de sauvegarde

Règle 3-2-1-1-0

Élément	Mise en œuvre (Cible)
3 copies	Production (A), réplique (B), sauvegardes (A, B et C)
2 supports	Disque (stockage de sauvegarde) et support amovible (bande ou disque hors ligne)
1 copie hors site	Site C
1 copie immuable ou hors ligne	Stockage à écriture unique au site C et copie hors ligne hebdomadaire en coffre
0 erreur	Vérification automatique de chaque sauvegarde (sommes de contrôle, restauration d'essai) ; toute erreur ouvre un incident

Calendrier

Donnée	Fréquence	Destination
Journaux de transactions PostgreSQL (WAL)	Archivage continu, restauration à un instant donné (PITR)	A, B et C
Base de données complète	Quotidienne	A et B, copie vers C

Donnée	Fréquence	Destination
Base de données incrémentale	Horaire	A et B, copie vers C
Stockage objet (biométrie, documents)	Réplication continue A ↔ B ; versionnement ; copie quotidienne	C
Journal d'audit	Export quotidien de la chaîne SHA-256 et de la tête de chaîne signée par HSM	C, en plus de la base
Configuration (Kubernetes, réseau, pare-feu)	À chaque changement, depuis le dépôt de configuration	A, B et C
Copie hors ligne	Hebdomadaire	Coffre du site C
Clés HSM	À chaque cérémonie de clés	Sauvegarde chiffrée partagée entre dépositaires, au site C et dans un second coffre

Conservation

La durée de conservation des données affichée dans WawID est de **5 ans** (paramètre `retentionDays`, 1 825 jours, Existant). La durée légale applicable est **À vérifier** avec la CDP et la DPAF. Les sauvegardes suivent la même règle : une donnée purgée de la production doit disparaître des sauvegardes au plus tard à l'expiration de leur propre durée de conservation. Le démonstrateur n'applique **aucune purge automatique** : la tâche de purge et d'archivage est **À développer**.

Chiffrement et clés

- Toutes les sauvegardes sont chiffrées avant de quitter le serveur qui les produit.
- Les clés de chiffrement des sauvegardes sont protégées par les HSM (clé maîtresse jamais exportée en clair).
- La restauration exige l'intervention de deux personnes habilitées (principe des quatre yeux).

Tests de restauration

Test	Fréquence	Critère
Restauration d'une base complète en préproduction	Trimestrielle	Base cohérente, durée mesurée, RPO constaté
Restauration à un instant donné	Trimestrielle	Retour à l'instant demandé
Restauration depuis le site C (copie immuable)	Semestrielle, lors des exercices	Reconstruction possible sans A ni B
Vérification du journal d'audit restauré	À chaque restauration	**Chaîne intègre** et tête de chaîne conforme à la dernière signature HSM

4. Haute disponibilité et reprise après sinistre

Scénarios de défaillance

Scénario	Détection	Décision	RTO visé	RPO visé	Actions principales
Perte d'un nœud (serveur, conteneur)	Supervision automatique	Automatique	Quelques minutes	0	Redémarrage ou reprise par les autres instances ; remplacement du nœud
Perte d'une baie ou d'une salle dans un site	Supervision	Automatique, puis responsable d'exploitation	Moins de 15 min	0	Bascule de la base vers la réplique locale ou distante ; capacité absorbée par l'autre site
Perte du site A	Supervision et arbitre	Automatique pour la base si l'arbitre confirme ; sinon décision de la cellule de crise	≤ 1 h	≤ 5 min (0 si réplication synchrone saine)	Promotion de la réplique de B ; DNS ou adresse virtuelle vers B ; vérification du journal d'audit ; information des postes
Perte du site B	Supervision	Automatique	Aucun arrêt (A reste primaire)	0	La réplication synchrone passe en mode dégradé (asynchrone vers C) ; alerte ; restauration de B
Indisponibilité des deux sites centraux	Supervision des postes	Cellule de crise	Reconstruction : à définir	Dernière copie reçue par C	Postes en mode hors ligne ; reconstruction depuis C ; resynchronisation des passages en file
Coupure de liaison d'un poste	Serveur de poste, supervision	Automatique	Bascule sur la liaison de secours en quelques minutes	0 (passages en file)	Secours 4G/VSAT ; sinon mode hors ligne ; resynchronisation au retour
Panne d'un HSM	Supervision	Automatique	Aucun arrêt (HSM jumeau)	0	Remplacement ; resynchronisation des clés par cérémonie
Rançongiciel ou corruption logique	SOC, SIEM	Cellule de crise et responsable sécurité	À définir selon l'étendue	Dernière copie saine, immuable	Isolement ; analyse ; restauration depuis copie immuable ; postes en mode hors ligne si nécessaire

Scénario	Détection	Décision	RTO visé	RPO visé	Actions principales
Coupure électrique d'un poste	Onduleur	Automatique	Aucun arrêt sur onduleur puis groupe	0	Bascule sur onduleur et groupe électrogène ; arrêt propre si autonomie épuisée

Les RTO et RPO ci-dessus sont des objectifs ; ils sont mesurés lors des exercices et ajustés.

Qui décide

Décision	Responsable
Bascule automatique d'un composant	Supervision (pas d'intervention humaine)
Bascule manuelle d'un site central	Responsable d'exploitation de WAW Telecom, après information de la DPAF
Déclenchement de la cellule de crise	Responsable d'exploitation ou responsable sécurité
Passage des postes en mode dégradé prolongé	DPAF (chef de poste, sur instruction de la direction)
Restauration depuis le site C	Cellule de crise, avec accord de la DPAF
Communication aux compagnies et au Trésor	Cellule de crise

Bascule d'un site central (procédure type)

1. Constater la panne (supervision, contrôle de santé, confirmation par l'arbitre) et ouvrir un incident majeur.
2. Vérifier que la réplique du site survivant est à jour (retard de réplication nul ou connu).
3. Promouvoir la réplique en primaire (automatique ou manuelle) et isoler l'ancien primaire pour éviter deux primaires simultanés.
4. Rediriger le trafic (DNS ou adresse virtuelle) vers le site survivant ; vérifier l'accès aux quatre plateformes et à la passerelle des compagnies.
5. Vérifier le **Journal d'audit** (**Chaîne intègre**) et l'accès aux HSM du site survivant.
6. Vérifier la resynchronisation des serveurs de poste.
7. Informer les postes, la DPAF, la DGCPT et les compagnies selon le plan de communication.
8. Consigner chaque étape et son heure.

Retour à la normale

1. Reconstruire ou réparer le site défaillant.
2. Le resynchroniser comme réplique du site devenu primaire.
3. Attendre une réplication synchrone stable.
4. Revenir au fonctionnement nominal pendant une fenêtre de maintenance planifiée (retour volontaire, jamais automatique).
5. Rédiger le retour d'expérience et mettre à jour les procédures.

Exercices

- **Deux exercices de reprise par an** au minimum : bascule réelle de A vers B, puis retour.
- Un exercice annuel de restauration complète depuis le site C.
- Un exercice annuel de coupure de liaison dans au moins un poste terrestre.
- Chaque exercice donne lieu à un compte rendu partagé avec la DPAF.

Procédures d'exploitation à rédiger

- Bascule et retour de la base de données.
- Bascule DNS ou adresse virtuelle.
- Remplacement d'un HSM et cérémonie de clés.
- Restauration complète et restauration à un instant donné.
- Reconstruction depuis le site C.
- Mode hors ligne d'un poste et resynchronisation.
- Réponse à un rançongiciel.
- Rotation des clés des équipements et des compagnies.
- Communication de crise.

5. Sécurité et conformité

Domaine	Mesure (Cible)
Segmentation	Zones séparées : exposition Internet (WAF, web public), API, données, administration, liaisons avec les postes, liaisons avec les partenaires ; filtrage entre zones
Accès d'administration	Bastion unique par site, authentification forte (MFA), comptes nominatifs, enregistrement des sessions, droits accordés pour une durée limitée
Identité des utilisateurs	OIDC, MFA et cartes agents PKI ; la MFA est **À développer** (le démonstrateur utilise identifiant et mot de passe)
Équipements	Remplacement de la clé partagée `WAWID_GATE_KEY` par des certificats par équipement (mTLS), **À développer**
Supervision de sécurité	SOC et SIEM 24 h/24, corrélation des journaux applicatifs, systèmes, réseau et HSM
Vulnérabilités	Analyse continue des images et des systèmes, correctifs selon la criticité, tests d'intrusion avant mise en service et au moins une fois par an
Journal d'audit	Chaîne SHA-256 (Existant) ancrée périodiquement par une signature HSM (À développer)
Données personnelles	Formalités CDP avant toute mise en production ; registre des traitements ; procédure de droits d'accès et de rectification
Sécurité physique	Contrôle d'accès des salles et des baies, vidéosurveillance, registre des interventions, baies fermées à clé pour les équipements WawID
Personnel	Habilitation des personnes ayant un accès privilégié (procédure **À vérifier** avec les autorités) ; engagement de confidentialité
Cérémonies de clés	Génération, sauvegarde et rotation des clés en présence de témoins, procès-verbal signé, dépositaires multiples

6. Phases de déploiement

Les durées sont **indicatives** et à confirmer à l'issue de la phase 0. Elles sont plus longues que celles de la note de proposition (`docs/PROPOSITION-REMPLACEMENT-SECURIPORT.md`), qui ne comprenait pas la construction de l'infrastructure haute disponibilité. Les phases 1 et 2 se déroulent en parallèle.

Phase	Contenu	Critères d'entrée	Critères de sortie	Durée indicative
0. Cadrage et juridique	Contrat ; formalités CDP ; convention avec Sénégal Numérique (site A) et avec le centre de données commercial (site B) ; choix du site C ; mandat d'encaissement de la redevance si le circuit `OPERATEUR` est retenu ; accords avec les détenteurs de fichiers	Décision de lancement	Conventions signées ; formalités CDP engagées ; architecture validée	1 à 3 mois
1. Construction des sites A, B et C	Baies, énergie, réseau, liaisons A ↔ B, opérateurs, pare-feu, WAF, HSM, Kubernetes, PostgreSQL, stockage objet, sauvegardes, SOC	Phase 0 terminée ; matériel livré	Tests d'infrastructure réussis, dont une bascule A → B et une restauration depuis C	3 à 6 mois
2. Migration de l'application	Passage du démonstrateur Netlify à la pile souveraine (voir le tableau ci-dessous)	Développements prioritaires lancés	Recette fonctionnelle sur la préproduction ; test de charge ; test d'intrusion	3 à 6 mois, en parallèle de la phase 1
3. Pilote AIBD	Quelques guichets et eGates aux arrivées et aux départs, en parallèle du système en place ; serveur de poste de l'AIBD ; passerelle ouverte à des compagnies volontaires ; rapprochement de la redevance	Phases 1 et 2 validées ; formalités CDP accomplies ; agents formés	Recette du pilote ; aucun incident bloquant pendant la période d'observation ; exercice de bascule réussi en conditions réelles	2 à 3 mois
4. Généralisation par vagues	Vague 1 : AIBD complet, ZIG, PDK. Vague 2 : ROS, KID, KAR (mode hors ligne indispensable)	Bilan du pilote ; serveurs de poste installés ; liaisons doublées	Recette par poste, dont un essai de coupure de liaison ; arrêt du système précédent selon les clauses contractuelles	1 à 2 mois par vague
5. Exploitation (MCO)	Supervision 24 h/24, maintenance, exercices, évolutions	Procès-verbal de mise en service	Revue annuelle	Continue

Migration du démonstrateur vers la pile souveraine (phase 2)

Élément	Démonstrateur (Existant)	Cible	État
API	Fonction unique `netlify/functions/api.mts` routée sur `/api/*`	Même code et mêmes routes dans un conteneur Node.js 22, derrière une passerelle ; le serveur local `dev-server.mjs` montre déjà que la fonction s'exécute hors Netlify	À développer (adaptateur et image de conteneur)
Stockage	Netlify Blobs via `netlify/lib/store.mts` : une collection = un document JSON réécrit à chaque écriture	PostgreSQL (transactions, tables partitionnées par mois) et stockage objet ; `store.mts` remplacé par un dépôt SQL ; fin du chargement global `/api/data`	À développer
Secrets	Variables d'environnement Netlify (`SESSION_SECRET` , `WAWID_GATE_KEY` , `WAWID_CARRIER_KEYS` , jetons des connecteurs)	Coffre à secrets et HSM ; clés distinctes pour les sessions et pour les QR codes	À développer
Fichiers statiques	`public/` publié par Netlify	Niveau web dans chaque site, derrière le WAF, un domaine par plateforme	À développer (configuration)
En-têtes de sécurité	`netlify.toml`	Reproduits sur le proxy inverse et le WAF	À développer (configuration)
Jeu de démonstration	Créé automatiquement si la base est vide (`netlify/lib/seed.mts`)	Désactivé en production	À développer
Journal d'audit	Chaîne SHA-256 dans le stockage	Table en ajout seul, ancrage HSM, export vers C	À développer (ancrage)
Identité	Mot de passe scrypt, session signée de 12 h	OIDC, MFA, cartes agents PKI	À développer
Mode hors ligne	Absent	Serveur de poste avec stockage et retransmission	À développer
Kiosques eGate	`/gate/` avec en-tête `X-Gate-Key`	Servis par le serveur de poste ; certificats par équipement	À développer
Pont NFC	`tools/nfc-bridge.mjs` , origine autorisée par `NFC_BRIDGE_ORIGIN`	`NFC_BRIDGE_ORIGIN` limité aux domaines de production (`dpaf.<domaine>` , domaine des kiosques)	Configuration
Application mobile	`mobile/` , API par défaut `https://wawid-waw-telecom.netlify.app`	Compilée avec `--dart-define=WAWID_API=https://api.<domaine>`	Configuration
Passerelle des compagnies	`POST /api/carrier/messages`	Même contrat, exposé sur `compagnies.<domaine>` derrière le WAF	Configuration

Élément	Démonstrateur (Existant)	Cible	État
Données	Fictives	Aucune reprise depuis le démonstrateur ; reprise éventuelle depuis le système en place selon les clauses contractuelles	À vérifier

Tests de réception

Test	Phase	Critère de réussite
Test de charge	2, puis avant chaque vague	10 transactions de contrôle par seconde soutenues et 50 en rafale ; pointe AIBD de 15 000 voyageurs par heure tenue par **un seul** site
Test de bascule A → B et retour	1, 3, puis deux fois par an	RTO ≤ 1 h ; RPO conforme ; journal d'audit intègre
Test de restauration (préproduction et depuis C)	1, puis chaque trimestre	Restauration complète réussie ; durée et perte mesurées
Test d'intrusion	2, avant le pilote, puis chaque année	Aucune vulnérabilité critique ou élevée ouverte
Coupure de liaison d'un poste	3 et 4	Contrôle poursuivi ; passages resynchronisés sans perte ni doublon
Perte d'un HSM	1	Aucune interruption de signature
Recette fonctionnelle	2 et 3	Tableau de recette du *Guide d'installation — Sénégal*

7. Environnements

Environnement	Emplacement	Données	Usage
Production	Sites A et B (actifs), C (coffre)	Réelles	Exploitation
Préproduction	Site B, isolée de la production	Synthétiques ou anonymisées	Validation des versions, tests de charge et de restauration, exercices
Test et formation	Site B ou environnement dédié	Fictives	Recette, formation des agents, essais des compagnies
Développement	WAW Telecom	Fictives	Développement, `npm test`
Démonstrateur Netlify	Netlify, hors du territoire	Fictives uniquement	Démonstrations ; aucune donnée personnelle réelle

Chaque environnement a ses propres secrets, clés et comptes. Une version n'est déployée en production qu'après validation en préproduction.

8. Exploitation

Supervision

- **Centre de supervision (NOC) 24 h/24 et 7 j/7**, couplé au SOC.
- Contrôles de santé des deux sites, de la réplication, des liaisons de chaque poste, des HSM, des sauvegardes et des certificats.
- L'état des équipements de poste remonte aussi dans **Supervision systèmes** de l'espace DPAF (Existant pour l'affichage ; remontée réelle À développer).
- Tableaux de bord de capacité et de performance, seuils d'alerte et astreinte.

Niveaux de service à négocier

Ces éléments sont à négocier avec Sénégal Numérique et le centre de données commercial ; aucune valeur n'est fixée dans ce plan :

- disponibilité de l'énergie et du refroidissement ;
- délais d'intervention sur site et d'accès d'urgence ;
- disponibilité et délai de rétablissement des liaisons opérateurs ;
- protection anti-DDoS et capacité de filtrage ;
- sécurité physique, contrôle d'accès et registre des visites ;
- notification des incidents et des maintenances planifiées ;
- conditions de réversibilité et de sortie ;
- pénalités en cas de manquement.

Capacité, correctifs et changements

- **Capacité** : revue trimestrielle de la charge réelle (passages, e-Visa, messages API/PNR, biométrie) par rapport au dimensionnement ; chaque site doit pouvoir porter seul la pointe.
- **Correctifs** : mise à jour site par site (B puis A), sans interruption grâce à l'actif-actif ; correctifs critiques en urgence selon la procédure de changement.
- **Changements** : comité de changement avec la DPAF ; fenêtres de maintenance planifiées et annoncées ; tout changement est d'abord appliqué en préproduction.
- **Maintenance planifiée** : de préférence aux heures creuses de trafic, communiquées à l'avance aux postes, aux compagnies et au Trésor.

Matrice des responsabilités (RACI)

R : réalise ; A : approuve et répond du résultat ; C : consulté ; I : informé. Répartition proposée, **À vérifier** dans les conventions.

Activité	WAW Telecom	DPAF	Sénégal Numérique	DC commercial	DGCPT	Compagnies
Hébergement du site A (énergie, salle, accès)	C	I	R/A	—	—	—
Hébergement du site B	C	I	—	R/A	—	—
Infrastructure et plateforme WawID	R/A	C	C	C	—	—

Activité	WAW Telecom	DPAF	Sénégal Numérique	DC commercial	DGCPT	Compagnies
Sauvegardes et restaurations	R	A	C	C	—	—
Décision de bascule d'un site	R	A	I	I	I	I
Exploitation des postes (procédures, mode dégradé)	C	R/A	—	—	—	—
Sécurité (SOC, vulnérabilités)	R	A	C	C	—	—
Formalités CDP	C	R/A	—	—	—	—
Redevance de sécurité (paramètres, encaissements)	R	I	—	—	A	C
Transmission API/PNR	C	A	—	—	—	R
Exercices de reprise	R	A	C	C	I	I

9. Nomenclature par site

Types d'équipements et quantités **à dimensionner** lors de l'étude détaillée ; aucun prix. Les quantités minimales indiquées découlent des principes de redondance.

Équipement	Site A	Site B	Site C	Chaque poste
Baies	À dimensionner	À dimensionner	1 ou 2	1 baie ou coffret
Routeurs (deux opérateurs)	2	2	1 ou 2	1 (+ routeur 4G/VSAT)
Pare-feu	Paire en haute disponibilité	Paire	1 ou paire	1
Commutateurs	Paire au minimum	Paire au minimum	1 ou 2	2
Répartiteurs de charge et WAF	Paire	Paire	—	—
Serveurs Kubernetes	3 nœuds de contrôle + nœuds de travail à dimensionner	Idem	—	—
Serveurs PostgreSQL	2 au minimum	2 au minimum (dont la préproduction séparée)	—	—
Stockage objet	4 nœuds au minimum (effacement codé)	4 nœuds au minimum	Stockage immuable à dimensionner	—
Bus d'événements	3 nœuds	3 nœuds	Arbitre éventuel	—
Serveurs ABIS (biométrie)	Selon le fournisseur	Selon le fournisseur	—	—
HSM	2	2	Sauvegarde des clés (coffre)	—

Équipement	Site A	Site B	Site C	Chaque poste
Sauvegarde	Serveur de sauvegarde	Serveur de sauvegarde	Appliance immuable + bandes ou disques hors ligne + coffre	—
Bastion et supervision	2 bastions, collecteurs SIEM	2 bastions, collecteurs SIEM	—	—
Serveurs de poste	—	—	—	2 nœuds
Énergie	Fournie par l'hébergeur (À vérifier)	Fournie par l'hébergeur	Selon le site	Onduleur + groupe électrogène

10. Risques et mesures

Risque	Conséquence	Mesure
Certification ou capacité d'un centre de données non confirmée	Niveau de disponibilité réel inférieur à l'objectif	Audit technique avant signature ; clause de capacité ; site B certifié
Sites A et B trop proches (même zone, même poste électrique)	Perte simultanée des deux sites	Préférer un site B distinct (Rufisque) ; vérifier les alimentations ; site C éloigné
Coupure de la liaison A ↔ B	Réplication synchrone interrompue ; risque de deux primaires	Deux chemins de fibre ; arbitre au site C ; bascule manuelle si l'arbitre est injoignable
Dépendance à un seul opérateur	Panne réseau générale	Deux opérateurs par site et par poste
Retard du mode hors ligne des postes	Postes terrestres arrêtés en cas de coupure	Priorité de développement ; procédure manuelle écrite ; vague terrestre conditionnée à sa validation
Rançongiciel	Chiffrement des données de production et des sauvegardes en ligne	Copies immuables et hors ligne ; segmentation ; MFA administrateurs ; exercices
Perte ou compromission des clés	Impossibilité de vérifier les QR, de restaurer ou de prouver l'intégrité	HSM par paires ; sauvegarde des clés partagée ; cérémonies
Formalités CDP ou textes de la redevance non aboutis	Mise en production bloquée	Lancement en phase 0 ; circuit `TRESOR` utilisable en attendant le texte du circuit `OPERATEUR`
Délais d'approvisionnement (HSM, serveurs, fibre)	Retard des phases 1 et 4	Commandes dès la fin de la phase 0 ; matériel de réserve
Compétences d'exploitation insuffisantes	Incidents mal traités	Formation, procédures écrites, exercices, transfert de compétences
Coupures électriques aux postes	Arrêt des équipements	Onduleurs, groupes électrogènes, tests réguliers
Charge supérieure aux hypothèses	Dégradation des temps de réponse	Marge ×5, revue trimestrielle, extension horizontale

11. Existant, cible et à développer

Sujet	Existant (démonstrateur)	Cible	À développer
Hébergement	Netlify, hors du territoire	Sites A et B au Sénégal + coffre C	Construction des sites
Stockage	Netlify Blobs, une collection par document JSON	PostgreSQL et stockage objet répliqués	Couche de stockage PostgreSQL
Disponibilité	Celle de Netlify, sans engagement souverain	99,95 % ou plus, deux sites actifs	Infrastructure, procédures, exercices
Sauvegardes	Aucune sauvegarde dédiée	Règle 3-2-1-1-0	Mise en place complète
Clés et secrets	Variables d'environnement	HSM par paires, coffre à secrets	Intégration HSM
Identité	Mot de passe, session de 12 h	OIDC, MFA, cartes PKI	MFA, OIDC
Postes	Navigateur relié directement au central	Serveur de poste, mode hors ligne	Serveur de poste et resynchronisation
Journal d'audit	Chaîne SHA-256 vérifiable	Chaîne ancrée par HSM, exportée vers C	Ancrage et export
Passerelle des compagnies	`POST /api/carrier/messages` ; un renvoi crée un nouveau message mais fusionne les passagers du même vol	Même contrat, derrière le WAF	Clé d'idempotence explicite et consignes de renvoi
Redevance	Circuit `OPERATEUR` par défaut (`settings.redevance.circuit`) ; circuit `TRESOR` disponible	Circuit retenu par les textes	Factures réelles ; texte et mandat si `OPERATEUR`
Conservation	5 ans affichés, sans purge	Purge et archivage conformes	Tâche de purge